



TYPO3



From Vulnerability to Stability: Inside TP03's Security Process



HOW WE KEEP TYP03 SECURE - QUALIFYING VS. NON-QUALIFYING VULNERABILITIES





SQL Injection



cross-site scripting (XSS)

Server-Side Request Forgery (SSRF)



Cross-Site Request Forgery (CSRF)

■ Insecure Direct Object Reference (IDOR)

■ Authentication & Authorization Flaws

(Sensitive) Information Disclosure



and more...

~~Non-qualifying~~ vulnerabilities

- Third-party software with known vulnerabilities

■ Install&MaintenModFlaws



Debug configuration

■ Wrapper Extensions (e.g. phpMyAdmin)



Public code, issues & reviews



Presented by



Dos attacks

Opinions without real security impact

- Outdated libraries without a demonstrated security impact



and many more. . .

Source: <https://typo3.org/community/teams/security/bug-bounty-program>

✅ **Qualifying vulnerabilities**

- SQL injection
- Cross-Site Scripting (XSS)
- Server-Side Request Forgery (SSRF)
- Cross-Site Request Forgery (CSRF)
- Insecure Direct Object Reference (IDOR)
- Authentication & Authorization Flaws
- (Sensitive) Information Disclosure
- *and more...*

❌ **Non-qualifying vulnerabilities**

- Third-party software with known vulnerabilities
- Install Tool & Maintenance Mode Flaws
- Debug configuration
- Wrapper Extensions (e.g. phpMyAdmin)
- Public code, issues & reviews
- Presence of banner or version information
- DoS attacks
- Open ports without real security impact
- Outdated libraries without a demonstrated security impact
- *and many more...*

Source: <https://typo3.org/community/teams/security/bug-bounty-program>

HOW WE KEEP TYPO3 SECURE – **SCOPES OF THE SECURITY TEAM**

